Universidad Ecotec

Administración integral de un centro de cómputo universitario

Actividad integradora 2: Diagnóstico, controles y plan de intervención de 90 días

Estudiante: Josué Chiriboga Mite

Carrera: Ingeniería en Sistémas

Asignatura: Administración de Centros de Cómputo

Docente: Ms. Christian Merchan Millán

Fecha: 1 de noviembre de 2026

Contenido

Introducción y datos del caso

Ítem 1. Inventario, control y mantenimiento

Ítem 2. Monitoreo y administración de redes y servicios

Ítem 3. Gestión del recurso humano técnico

Ítem 4. Seguridad en IoT e inteligencia artificial

Ítem 5. Ciberseguridad en redes e infraestructuras críticas

Plan integrador de 90 días

Reflexión final

Referencias

Anexo A. Muestra de inventario y mantenimiento

Anexo B. Habilidades e indicadores

Anexo C. Umbrales y escalamiento

Anexo D. Inventario IoT y hardening

Anexo E. Matriz de intervención, impacto y riesgos

Anexo F. Recuperación ante desastres

Anexo G. Declaración de uso de inteligencia artificial

Introducción y datos del caso

El caso integra contenidos de todo lo aprendido en clases, infraestructura, servicios, inventario, personal, seguridad, continuidad, automatización e indicadores. La Universidad Regional Andina (URA) ficticia atiende a 14.000 estudiantes y 1.100 funcionarios; dispone de 38 servidores físicos, unas 160 máquinas virtuales, dos SAN, seis laboratorios con 240 equipos, dos UPS, generador, CRAC e IoT. El análisis organiza controles y evidencias conforme a las funciones de gobernar, identificar, proteger, detectar, responder y recuperar (National Institute of Standards and Technology [NIST], 2024).

Supuestos y alcance

Las fechas se cuentan del 2 de noviembre de 2026 (día 0) al 31 de enero de 2027 (día 90); los costos son rangos indicativos en USD, no cotizaciones. Los objetivos de recuperación requieren validación mediante análisis de impacto y pruebas. Los perfiles del anexo son ficticios. Los 37 equipos sin registro están incluidos en los 240; no se conocen modelos, compras ni firmware, que se marcarán “por verificar”. Se asume que el DDoS duró seis horas y que quedó sin recuperar el 20 % de la información. Los daños financieros y de privacidad no fueron cuantificados.

Ítem 1. Inventario, control y mantenimiento

Proceso de registro y ciclo de vida

Conciliar los 240 equipos de los seis laboratorios con Compras, GLPI y red, empezando por los 37 faltantes. Dos personas verifican etiqueta/serial, puesto y custodio; documentan discrepancias y crean un registro GLPI con evidencia. Etiquetar con QR e identificador URA-

LOC-TIPO-000001, sin exponer datos sensibles. Cada movimiento, préstamo, reparación, incidente y cambio se enlaza al activo; una baja requiere autorización, retiro de licencias/accesos, borrado seguro cuando aplique y acta.

Registrar identificador y serial; clase/fabricante/modelo; campus, laboratorio, puesto/rack; custodio y responsable técnico; fecha/fuente de adquisición; estado de ciclo de vida; SO/licencias/soporte; criticidad; IP/MAC si aplica; historial fechado de movimientos, mantenimiento, incidentes y cambios; garantía, última verificación y documentos. Usar estados controlados: recibido, servicio, reparación, préstamo, cuarentena o retirado.

Herramienta recomendada

Conservar GLPI y habilitar el agente o mecanismo de inventario compatible con la versión instalada, junto con QR y conciliación con Compras. La documentación oficial describe gestión de activos e inventario; probar compatibilidad antes de activar agentes/complementos (GLPI Project, s. f.). Reutiliza una herramienta existente y relaciona activos con tickets y cambios; aunque la licencia comunitaria puede no tener costo, soporte y operación sí lo tienen. No duplicar inventario con Lansweeper/OCS salvo que una prueba identifique una brecha. Las hojas de cálculo solo sirven para importación controlada.

Meta al día 30: verificar 240/240, resolver o escalar los 37 faltantes y documentar la baja del servidor en bodega. Conciliar semanalmente GLPI, compras y red; revisar mensualmente muestra del 10 %, activos críticos, licencias y registros sin custodio. El Anexo A muestra los campos y el cronograma.

Ítem 2. Monitoreo y administración de redes y servicios

Disponibilidad y realismo del SLA

En 365 días hay 8.760 horas: 99,9 % permite 8,76 h; 99,99 %, 52,56 min; 99,999 %, 5,256 min. El cálculo es (1 − objetivo) × 8.760. Seis horas equivalen a 0,0685 % del año y, sin más caídas, 99,9315 % anual: consume 68,5 % del presupuesto de 99,9 % y deja 2,76 h; excede los presupuestos de los otros dos objetivos. Por ello, 99,9 % es viable solo tras corregir DDoS, escalamiento y recuperación. Medir con transacciones sintéticas externas cada minuto y definir contractualmente ventanas y exclusiones; la gestión de SLI/SLO y presupuesto de error evita promesas no respaldadas (Beyer et al., 2016).

Métricas y umbrales propuestos

Para el portal medir disponibilidad sintética, latencia p95/p99, errores HTTP 5xx, CPU, memoria, I/O y conexiones de base de datos. Para la red medir latencia RTT, pérdida, uso del enlace y puertos, errores de interfaz y estado de firewall. Umbrales iniciales: p95 > 1 s o errores > 1 % = advertencia; p95 > 2 s o errores > 5 % = crítico; CPU > 75/90 %, enlace > 70/85 % y SAN > 10/20 ms (advertencia/crítico). Calibrarlos con línea base y matrícula. Correlacionar por dependencias y revisar triggers, acciones, guardias y permisos de Zabbix (Zabbix, s. f.; Anexo C).

Escalamiento N0–N3 y aplicación al DDoS

N0 detecta; N1 valida, abre ticket y ejecuta runbook; N2 diagnostica sistema/red/BD y lidera recuperación; N3 integra dirección, seguridad/IR, ISP anti-DDoS y fabricantes. Para P1, N1 reconoce en ≤ 5 min, avisa N2 en ≤ 10 min y activa N3/proveedor en paralelo; no espera reproducción. En el DDoS, debió abrirse puente P1, preservar logs, verificar tráfico, activar

mitigación upstream y reglas temporales aprobadas, informar a Admisiones por canal alterno y probar transacciones antes de cerrar. Registrar cronología, causa raíz y lecciones sin culpabilización. La matriz y runbook están en el Anexo C.

Ítem 3. Gestión del recurso humano técnico

Roles, cobertura y continuidad del conocimiento

La estructura no confirma suplencia VMware ni DBA, y no identifica responsable de seguridad/SOC; los operadores no reemplazan a especialistas. Confirmar si “tres operadores por turno” significa tres en total o por turno. Para cobertura continua se necesita un puesto NOC por turno con relevo planificado (aprox. cinco equivalentes a tiempo completo por puesto 24/7, sujeto a normativa), más guardias de sistemas, redes, DBA e infraestructura. Designar responsable de incidentes y seguridad con autoridad; no es necesario tener todos los especialistas en sitio de madrugada si el escalamiento 24/7 está probado.

El riesgo de persona clave es muy alto en VMware (un experto) y alto en BD (DBA parcial sin suplente confirmado). En 30 días asignar suplentes, transferir conocimiento y documentar runbooks; en 60 días, dos personas deben poder ejecutar cada tarea crítica. La matriz ficticia del Anexo B identifica competencias y brechas; cuentas compartidas no son una solución.

Habilidades e indicadores

Los indicadores mensuales son: MTTR P1 ≤ 4 h; resolución N1 en primer contacto ≥ 70 % de casos elegibles; reaperturas ≤ 5 % en siete días; y cumplimiento documentado de procedimientos ≥ 95 %. MTTR se informa por mediana y P90. El plan individual del

administrador VMware documenta diez runbooks, forma dos suplentes y demuestra una restauración antes del día 45 (Anexo B).

Ítem 4. Seguridad en IoT e inteligencia artificial

Clasificación de IoT y explicación del pivote

Riesgo alto: cámaras (30), por admin/admin ya explotado; crítico: PDU (8) y controladores CRAC (2), pues permiten afectar energía/clima; medio-alto: sensores (42), por datos falsos o congelados. Aislar en VLAN, bloquear rutas hacia VMware/SAN/administración y permitir solo colectores y servicios requeridos. Cambiar credenciales, activar MFA donde exista, actualizar firmware soportado, desactivar servicios innecesarios, usar HTTPS/SNMPv3, registrar cambios y validar heartbeat/calibración. Modelos y versiones quedan por levantar; NIST recomienda definir requisitos de seguridad desde dispositivo y proveedor (Fagan et al., 2021; Anexo D).

La cámara con admin/admin permitió acceso inicial; reglas permisivas y segmentación insuficiente hicieron posible el pivote hasta VMware. El retraso de dos días en revisar logs muestra brechas de telemetría y respuesta. No se conoce la técnica intermedia ni se atribuye una vulnerabilidad concreta. La solución combina mínimo privilegio, segmentación y verificación por recurso, no confianza por ubicación de red (Rose et al., 2020).

Riesgos de IA y controles

Riesgos: evasión del SIEM para ocultar eventos; envenenamiento del predictor con lecturas falsas/congeladas; y manipulación del optimizador para concentrar cargas o agotar recursos. Mantener reglas deterministas y fuentes originales; validar procedencia, rango,

continuidad y calibración; autenticar colectores y almacenar hashes encadenados/bitácora append-only (el hash no prueba veracidad de origen). La IA solo recomienda cambios. Auditar entrada, versión, salida, confianza, aprobación y resultado; medir drift y falsos negativos. Desactivar ante datos íntegros no verificables, drift fuera del umbral o falsos negativos graves; volver a reglas manuales y reentrenar solo con datos depurados/aprobados (Tabassi, 2023).

Ítem 5. Ciberseguridad en redes e infraestructuras críticas

Amenazas materializadas y pendientes

Materializadas: DDoS; cámara con credencial predeterminada y pivote a VMware; phishing y robo de cuenta administrativa; intento de cifrado y recuperación parcial; sensor congelado, fuente averiada, generador fallido y UPS al 12 %; inventario, licencias y baja sin trazabilidad. Abiertas, no confirmadas: persistencia, exfiltración, abuso de otras cuentas, otros IoT comprometidos, incendio/inundación, sabotaje y nuevas fallas SAN/CRAC. Investigar y conservar evidencia antes de declarar un impacto; organizar respuesta conforme al CSF (NIST, 2024).

Gestión de accesos privilegiados

Implantar PAM para VMware, SO, BD, firewall, respaldos y energía: bóveda cifrada, cuenta individual, MFA, mínimo privilegio/JIT, rotación automática, aprobación dual para cambios críticos y grabación SSH/RDP. Alertar sobre accesos anómalos; revisar cuentas de servicio y revocar accesos el día del traslado. Cuentas de emergencia selladas, probadas trimestralmente y con alerta inmediata. Iniciar por VMware/firewall/respaldo; centralizar logs fuera del control de administradores (Rose et al., 2020).

Plan integrador de 90 días

Prioridades y secuencia

Priorizar contención, copias recuperables, energía/sensores, IoT, monitoreo y trazabilidad; luego suplencias, cambios y ejercicios. Las diez acciones, fechas, responsables, costo, indicador y evidencia se detallan en el Anexo E. El DRP y sus RTO/RPO deben derivarse del impacto por servicio y probarse: una copia existente no equivale a recuperación verificada (Swanson et al., 2010).

Priorización impacto–esfuerzo

La matriz de dos ejes prioriza primero las acciones de alto impacto y bajo o medio esfuerzo; las inversiones de alto esfuerzo se ejecutan después de contener amenazas y asegurar recuperación. La matriz completa y su relación con responsables, plazos, costos, indicadores y evidencias se presenta en el Anexo E.

Los costos y la evidencia por acción están detallados en el Anexo E. Se reservará una contingencia de 15 % dentro del presupuesto; la compra se somete a cotización y aprobación. Los registros requeridos por el ente de control (inventario, DRP, cambios e incidentes) se generan desde el inicio, con propietario, fecha, fuente y revisión, no se reconstruyen al final.

Riesgos de implementación

Riesgos: falta de presupuesto —secuenciar y documentar aceptación temporal con vencimiento—; sobrecarga/resistencia —reservar horas, formar y automatizar—; dependencia de proveedor —exigir exportación, documentación, guardia y prueba de salida—. Cambios durante

matrícula pueden interrumpir servicio: exigir ventana aprobada, prueba, reversa y doble revisión; congelar cambios no urgentes.

Reflexión final

El caso muestra que la continuidad no depende de una herramienta aislada, sino de personas, procesos y tecnología con controles comprobables. Una cámara con credenciales predeterminadas llegó a virtualización por segmentación insuficiente, permisos y detección tardía. El DDoS evidenció que la promesa de disponibilidad no estaba respaldada por escalamiento; la falla eléctrica y los sensores congelados mostraron que la IA no reemplaza mantenimiento ni datos confiables; recuperar solo el 80 % confirmó que una copia no es necesariamente recuperable.

La respuesta prioriza contener accesos, segmentar, proteger copias y restablecer energía; luego fortalece inventario, monitoreo, cambios y suplencias. Se aprendió a vincular cada acción con un dueño, evidencia y prueba, y a no automatizar decisiones de impacto sin supervisión. La limitación principal es la falta de topología, volúmenes, contratos, análisis forense, precios y versiones de firmware. Por ello, costos, umbrales y RTO/RPO son objetivos provisionales que requieren BIA, cotizaciones y pruebas. El estudiante debe personalizar y validar el trabajo antes de entregarlo.

Referencias

Beyer, B., Jones, C., Petoff, J., & Murphy, N. R. (Eds.). (2016). Site reliability engineering: How Google runs production systems. O'Reilly Media. https://sre.google/sre-book/table-of-contents/

Fagan, M., Marron, J., Brady, K., Cuthill, B., Megas, K., Herold, R., Lemire, D., & Hoehn, B. (2021). IoT device cybersecurity guidance for the federal government: Establishing IoT device cybersecurity requirements (NIST Special Publication 800-213). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-213

GLPI Project. (s. f.). GLPI documentation. https://help.glpi-project.org/

International Organization for Standardization. (2022). Information security, cybersecurity and privacy protection—Information security management systems—Requirements (ISO/IEC Standard No. 27001:2022). https://www.iso.org/standard/82875.html

National Institute of Standards and Technology. (2024). The NIST cybersecurity framework (CSF) 2.0 (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). Zero trust architecture (NIST Special Publication 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207

Swanson, M., Bowen, P., Phillips, A., Gallup, D., & Lynes, D. (2010). Contingency planning guide for federal information systems (NIST Special Publication 800-34 Rev. 1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-34r1

Tabassi, E. (2023). Artificial intelligence risk management framework (AI RMF 1.0) (NIST AI 100-1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.AI.100-1

Zabbix. (s. f.). Zabbix manual. https://www.zabbix.com/documentation/current/en/manual

Anexo A. Muestra de inventario y mantenimiento

Los siguientes registros son ejemplos ficticios de formato, no datos reales de los equipos URA. La fecha “por verificar” obliga a consultar factura/Compras; no se interpreta como fecha de adquisición. Los 10 registros no sustituyen la conciliación completa de los 240 equipos.

Tabla A1

Muestra de registro patrimonial

Código / etiqueta	Activo	Ubicación	Responsable	Adquisición	Historial resumido	Estado
URA-LAB01-PC001	PC estudiante	Lab. 1, puesto 01	Custodio Lab. 1	Por verificar	Alta de auditoría; sin factura vinculada	En servicio; validar serial
URA-LAB01-PC002	PC estudiante	Lab. 1, puesto 02	Custodio Lab. 1	Por verificar	Verificación física; etiqueta QR pendiente	En servicio
URA-LAB02-PC037	PC estudiante	Lab. 2, puesto 06	Custodio Lab. 2	Por verificar	Uno de 37 sin registro; alta correctiva	En servicio; revisar licencia
URA-LAB03-PC014	PC estudiante	Lab. 3, puesto 14	Custodio Lab. 3	Por verificar	Historial por importar desde hoja de cálculo	En servicio
URA-LAB04-PC021	PC estudiante	Lab. 4, puesto 21	Custodio Lab. 4	Por verificar	Incidentes/ mantenimiento por conciliar	En servicio
URA-LAB05-PC008	PC estudiante	Lab. 5, puesto 08	Custodio Lab. 5	Por verificar	Verificado en conteo físico de ejemplo	En servicio
URA-LAB06-PC040	PC estudiante	Lab. 6, puesto 40	Custodio Lab. 6	Por verificar	Revisar número de serie y sistema operativo	En servicio
URA-SRV-VIRT01	Host virtualización	Sala de servidores, rack por asignar	Admin. de sistemas	Por verificar	Host relacionado con incidente; preservar evidencia	Cuarentena hasta liberación forense
URA-BKP-SRV01	Servidor de respaldo	Sala de servidores	Admin. de respaldos	Por verificar	Intento de cifrado; verificar restauración e inmutabilidad	Restringido; no confiar hasta validar
URA-GEN-001	Generador diésel 200 kVA	Planta eléctrica	Infraestructura física	Por verificar	Prueba fallida por batería descargada	En servicio condicionado; riesgo crítico

Tabla A2

Cronograma preventivo mínimo propuesto

Frecuencia	Actividad	Responsable	Registro / evidencia
Diaria	Revisar alertas, sensores sin señal, capacidad, copias fallidas y tickets P1.	Operador de turno	Checklist NOC y ticket con hora/resultado.
Semanal	Conciliar altas/cambios GLPI–Compras; revisar activos sin custodio y licencias.	Activos + Compras	Reporte de discrepancias y responsables/fecha límite.
Mensual	Prueba de restauración de muestra; comprobar estado de UPS, sensores y alarmas CRAC; revisar firmware disponible.	Sistemas, respaldo e infraestructura	Acta de prueba, logs, mediciones y acciones correctivas.
Trimestral	Prueba bajo carga del generador,	Infraestructura + director	Orden de trabajo, proveedor,

Frecuencia	Actividad	Responsable	Registro / evidencia
	autonomía UPS según procedimiento fabricante, acceso físico y restauración integral por servicio.		resultado, plan de reversa y aprobación.
Semestral	Revisión física aleatoria del 10 % del inventario y recuperación de configuración de red/hipervisor.	Auditoría interna + TI	Muestra, hallazgos, evidencia y seguimiento.
Anual / tras cambio	Actualizar plan de continuidad, matriz de riesgos, contactos, licencias y análisis de capacidad.	Director + dueños de servicio	Versión aprobada, control de cambios y acta de ejercicio.

Anexo B. Habilidades e indicadores

Escala: 0 = sin formación; 1 = fundamentos; 2 = operación autónoma con procedimientos; 3 = experto/formador. Las asignaciones son ficticias para demostrar cobertura y deben reemplazarse por evaluación real.

Tabla B1

Matriz de habilidades ilustrativa

Persona ficticia	Rol	Fortalezas (nivel)	Brecha / cobertura	Diagnóstico
Andrea Molina	Directora	Gestión/ITSM 3; incidentes 2	VMware 1; DBA 0	Gobierno y decisión; no es operadora técnica.
Luis Vega	Admin. sistemas	VMware 3; respaldo 2	Seguridad 2; SAN 2	Especialista VMware único; riesgo muy alto.
Carla Ruiz	Admin. sistemas	Windows/Linux 2; VMware 1	Respaldo 2; seguridad 1	Suplente VMware por formar y evaluar.
Mateo Cedeño	Admin. redes	Redes/firewall 3; Zabbix 2	IR 2; IoT 1	Lidera contención de red; capacitar en forense.
Sofía León	DBA parcial	DBA 3; SQL 3	Respaldo BD 2; continuidad 1	Punto único; disponibilidad parcial.
Rosa Paredes	Operadora	NOC/tickets 2; runbook 2	Escalamiento 2; seguridad 1	Turno; no administra sistemas críticos.
Diego Mora	Operador	NOC/tickets 2; monitoreo 2	Respaldo 1; seguridad 1	Turno; práctica de detección.
Elena Ruiz	Operadora	NOC/tickets 2; comunicaciones 2	Incidentes 1; respaldo 1	Turno; simulacro de P1 requerido.
Pablo Vera	Téc. infraestructura	UPS/generador 2; CRAC 2	IoT 1; seguridad física 2	Acompañar pruebas con proveedor.
Inés Castro	Téc. infraestructura	Energía 2; sensores 2	CRAC 1; documentación 2	Suplencia de mantenimiento físico.

Tabla B2

Indicadores y plan individual

Indicador	Fórmula / alcance	Meta	Frecuencia y dueño
MTTR P1	Mediana desde apertura hasta restauración; desglosar P90 por tipo.	≤ 4 horas	Mensual; responsable de servicio.
Resolución en primer contacto	Tickets elegibles resueltos en N1 sin transferencia / tickets elegibles.	≥ 70 %	Mensual; líder de mesa/NOC.
Reapertura	Tickets reabiertos en 7 días / tickets cerrados.	≤ 5 %	Mensual; dueño de proceso.
Cumplimiento de procedimientos	Muestra de incidentes/cambios con checklist, aprobación y evidencia completa.	≥ 95 %	Mensual; auditoría interna.
Plan de desarrollo: Luis Vega	Documentar diez runbooks VMware, formar a Carla y a otro administrador, ejecutar dos cambios supervisados y una restauración de prueba.	Dos suplentes nivel 2 al día 45; evidencia aprobada.	Semanal; Andrea valida, Carla ejecuta.

Anexo C. Umbrales y escalamiento

Los umbrales son iniciales y deben calibrarse con línea base, SLO y dependencias antes de convertirse en alertas de guardia. Ventana sugerida: advertencia en 5–15 minutos persistentes; crítico en 5 minutos para síntomas de servicio o de inmediato ante evento de seguridad.

Tabla C1

Umbrales sugeridos para portal e infraestructura

Métrica	Advertencia	Crítico	Respuesta
Disponibilidad sintética portal	Error en 2 de 5 pruebas consecutivas o transacción > 1 min fallida.	Fallo desde dos ubicaciones en 2 pruebas consecutivas.	P1 si afecta usuarios; N1 valida y escala.
Latencia portal p95	> 1 s por 10 min.	> 2 s por 5 min o timeout de transacción.	Correlacionar APM, app, BD y enlace.
Errores HTTP 5xx	> 1 % durante 5 min.	> 5 % durante 5 min.	Revisar tasa/volumen y dependencias.
CPU / memoria host	CPU > 75 % por 15 min; memoria > 80 %.	CPU > 90 % por 5 min; memoria > 90 % con presión sostenida.	Capacidad, VM ruidosa y cambio reciente.
SAN / disco	Espacio > 75 %; latencia > 10 ms sostenida.	Espacio > 85 %; latencia > 20 ms o error de ruta.	Alerta de capacidad y responsable storage.
Internet / core	Utilización > 70 % por 15 min; pérdida > 1 %.	> 85 % por 5 min; pérdida > 3 % o enlace abajo.	Correlacionar proveedor, firewall y núcleo.
Sensores / IoT	Dato constante > 15 min o ausencia > 2 intervalos.	Sin telemetría > 30 min o salto ambiental alto.	No confiar en IA; operador verifica en sitio.
Seguridad	Alerta de reputación o intentos anómalos.	Credencial privilegiada comprometida, movimiento lateral o DDoS confirmado.	P1: preservar evidencia, aislar con autorización.

Tabla C2

Matriz de escalamiento N0–N3

Nivel	Quién / cobertura	Tiempo máximo P1	Manual y herramientas
N0	Zabbix, pruebas sintéticas, SIEM; monitoreo automatizado 24/7.	Detección continua; generar ticket al umbral.	Runbook de alertas, dashboard, correlación y dependencias.
N1	Operador NOC de turno; reconoce, valida, comunica y ejecuta pasos seguros.	Reconocer ≤ 5 min; notificar N2 ≤ 10 min.	GLPI incidente P1, checklist, teléfono/guardia y canal alterno.
N2	Admin. de sistemas/redes/DBA según servicio; gerente incidente.	Inicio diagnóstico ≤ 15 min; líder designado en paralelo.	Runbook técnico, PAM, logs, cambios urgentes aprobados.
N3	Director, seguridad/IR, ISP anti-DDoS, fabricante y autoridades según política.	Activación inmediata; llamada del proveedor ≤ 15 min.	Plan IR/DRP, contactos, preservación de evidencia, comunicación ejecutiva.

Anexo D. Inventario IoT y hardening

Conteos según escenario; modelo y versión de firmware no fueron informados y deben completarse antes de aceptar el riesgo. “Por levantar” es un hallazgo explícito, no una versión inventada.

Tabla D1

Clasificación y controles de IoT

Grupo / cantidad	Riesgo	Falla probable / dato actual	Hardening y monitoreo	Firmware / responsable
Cámaras IP / 30	Alto	Credencial admin/admin ya explotada; firmware desconocido.	Rotar credenciales únicas; VLAN aislada; HTTPS; desactivar UPnP/Telnet; permitir solo NVR/NTP/DNS necesarios; bloquear administración desde usuario.	Versión por levantar; Red + Seguridad.
PDU inteligentes / 8	Crítico	Control de energía por web/SNMP; credenciales y exposición por verificar.	VLAN de gestión; MFA si soporta; SNMPv3; sin acceso desde IoT/usuario; doble aprobación para apagado; logs y configuración respaldados.	Versión por levantar; Infraestructura + Redes.
Sensores temp./humedad / 42	Medio-alto	Dos valores constantes tres semanas; autenticidad/calibración débiles.	Autenticación del colector; heartbeats; umbral de dato constante; calibración; cruce con sensor independiente; conservar dato crudo.	Modelo/firmware por levantar; Infraestructura.
CRAC / 2 controladores	Crítico	Pérdida de control climático por firmware/acceso de proveedor.	Red de control segregada; acceso remoto temporal con MFA y grabación; allowlist; respaldo de configuración; doble sensor y alarma fuera de banda.	Versión por levantar; Infraestructura + proveedor.

Regla de segmentación propuesta: los dispositivos solo se comunican con su colector/controlador definido y servicios indispensables; el colector envía telemetría a monitoreo. Se bloquea por defecto tráfico dispositivo → host VMware, SAN, respaldo y redes de administración. Una excepción requiere dueño, motivo, puerto, origen/destino, vencimiento y aprobación de cambio. La revisión de firmware se hace en entorno de prueba y con ventana de reversa.

Anexo E. Matriz de intervención, impacto y riesgos

Día 0 = 2 de noviembre de 2026. Rangos USD de orden de magnitud; combinan horas de personal, herramientas/servicios y pequeñas adquisiciones. Las evidencias son ejemplos de expediente de auditoría; la correspondencia final con controles ISO/IEC 27001:2022 debe validarse con la versión licenciada de la norma y el alcance del SGSI.

Impacto / esfuerzo	Esfuerzo bajo	Esfuerzo medio	Esfuerzo alto
Alto	Rotar credenciales; runbook P1; acta de baja.	Regularizar inventario; sensores; umbrales.	PAM; segmentación IoT; copia inmutable; protección DDoS.
Medio	Asignar custodios y suplentes; registrar firmware.	Conciliar compras/licencias; formación cruzada.	Modernización no urgente solo tras cerrar brechas críticas.
Bajo	Mejoras de formato de reportes.	Automatización después de estabilizar controles.	No priorizar proyectos sin vínculo con riesgos actuales.

Tabla E1

Tabla E2

Acciones, responsables, calendario, costo y evidencia

Acción / alcance	Responsable	Fechas	Costo	Indicador de éxito	Evidencia / trazabilidad ISO
A1. Contener incidentes: rotar credenciales, preservar logs, investigar host y cuentas, activar mitigación DDoS.	Director + Redes + Sistemas + respuesta externa	D0–D7 (Nov. 2–9)	$2–8 mil	Cuentas privilegiadas expuestas revocadas; análisis inicial; plan de mitigación probado.	Ticket P1, línea de tiempo, logs sellados, comunicación y postmortem; ISO A.5.24–5.28, A.8.15.
A2. Reforzar respaldo: separar credenciales, inmutabilidad/offline, regla 3-2-1-1-0, restaurar una muestra prioritaria.	Sistemas + DBA + director	D0–D20 (Nov. 2–22)	$5–20 mil	Restauración íntegra documentada de sistemas críticos y cobertura de copia inmutable.	Política, configuración, reportes de backup/restore, RPO medido; ISO A.8.13.
A3. Recuperar energía y ambiente: baterías, UPS al 12 %, generador, sensores congelados y CRAC.	Infraestructura física + proveedor	D0–D15 (Nov. 2–17)	$4–15 mil	Prueba aprobada; sensores con heartbeat; autonomía y alarmas verificadas.	Órdenes, mediciones, calibración, pruebas y acciones; ISO A.7.11.
A4. Reconciliar inventario de 240 equipos; regularizar 37, nueve licencias y servidor sin acta.	Responsable de activos + Compras + operadores	D0–D30 (Nov. 2–Dic. 2)	$1–5 mil	240/240 verificados; 37 resueltos/escalados; 100 % de bajas con acta.	Exportes GLPI, actas, órdenes de compra, licencias; ISO A.5.9, A.5.11.
A5. Segmentar IoT y endurecer cámaras/PDU/sensores/ CRAC; cerrar rutas al hipervisor.	Redes + Seguridad + Infraestructura	D5–D35 (Nov. 7–Dic. 7)	$5–18 mil	Prueba negativa confirma que IoT no llega a VMware/SAN; 100 % de credenciales cambiadas.	Diagrama, ACL/firewall aprobados, escaneo autorizado y configuración; ISO A.8.20–8.22.
A6. Restablecer monitoreo: línea base, umbrales, pruebas externas, contactos/guardias, runbooks y dependencia de servicios.	Redes + Sistemas + NOC	D5–D30 (Nov. 7–Dic. 2)	$2–8 mil	P1 reconocido en ≤ 5 min en simulacro; umbrales revisados y ruido reducido.	Exportes Zabbix, alertas, checklist, simulacro/ticket; ISO A.8.16.
A7. PAM fase 1 en VMware, firewall y respaldo; MFA, bóveda, rotación,	Director + Seguridad + Redes/Sistemas	D10–D60 (Nov. 12–Ene. 1)	$10–35 mil	100 % de cuentas privilegiadas identificadas; sesiones críticas grabadas;	Inventario de cuentas, matriz acceso, bitácora PAM, evidencia de revisión; ISO A.5.15–

Acción / alcance	Responsable	Fechas	Costo	Indicador de éxito	Evidencia / trazabilidad ISO
aprobación y grabación.				rotación probada.	5.18, A.8.2.
A8. Gestión de cambios e incidentes: aprobaciones, reversa, guardias, comunicación y revisión posterior.	Director + dueños de servicio	D15–D45 (Nov. 17–Dic. 17)	$1–6 mil	≥ 95 % de cambios muestreados con aprobación, pruebas y reversa; P1 postmortem.	Procedimiento, CAB, tickets y registro de excepciones; ISO A.5.24–5.28, A.8.32.
A9. Formación cruzada VMware/DB y plan de retención/documentación para personal clave.	Director + Sistemas + DBA	D15–D60 (Nov. 17–Ene. 1)	$2–10 mil	Dos suplentes nivel operativo evaluados; procedimientos críticos aprobados.	Matriz de competencias, asistencia, pruebas prácticas y runbooks; ISO A.6.3.
A10. DRP, análisis de impacto y ejercicio de recuperación/tabla; gap analysis ISO 27001.	Director + dueños de negocio + TI + auditoría	D45–D90 (Dic. 17–Ene. 31)	$4–15 mil	Servicios con RTO/RPO aprobados; ejercicio ejecutado y acciones con responsables.	BIA, DRP versionado, acta de ejercicio, tiempos reales, plan de tratamiento; ISO A.5.29–5.30.

Inversión indicativa total: aproximadamente USD 36.000–140.000 antes de contingencia, según cotización de PAM, inmutabilidad, soporte del fabricante y estado real de baterías/sensores. El rango no constituye autorización de compra. Priorizar primero A1–A6; una limitación presupuestaria no puede justificar mantener credenciales por defecto ni dejar de preservar evidencias.

Tabla E3

Riesgos de ejecución y respuestas

Riesgo	Impacto	Respuesta / propietario	Señal de alerta
Presupuesto no aprobado o licitación lenta	Controles críticos atrasados; deuda de riesgo abierta.	Priorizar medidas de bajo costo; aprobación ejecutiva por fases; registrar aceptación temporal con vencimiento. Director.	A1/A2 sin orden de compra o fecha al día 10.
Resistencia y sobrecarga del equipo	Inventario y runbooks incompletos; errores por cambios.	Asignar tiempo protegido, capacitación breve, operadores como custodios, automatizar importación y comunicar beneficio. Director de TI.	Tareas vencidas > 10 % o turnos sin suplente.
Dependencia de proveedor/PAM/DR	Bloqueo de servicio o de conocimiento.	Cláusulas de exportación, documentación, pruebas de salida, cuentas de emergencia y capacitación interna. Compras + TI.	No hay exportación/configuración o proveedor no confirma guardia.
Cambios causan nueva caída durante matrícula	Incumplimiento de SLA y daño académico.	Ventanas aprobadas, prueba previa, rollback, doble revisión, congelamiento de cambios no urgentes. Dueño del portal.	Cambios productivos sin ticket, pruebas o reversa.

Anexo F. Recuperación ante desastres

Los RTO/RPO siguientes son objetivos propuestos para validar con Admisiones, Finanzas, Registro Académico y propietarios de datos. No representan capacidad demostrada. Antes de aprobarlos se mide volumen, dependencias, licencias, capacidad de enlace y tiempo de restauración. El diseño debe incluir sitio o copia fuera del dominio administrativo comprometible, credenciales separadas y pruebas recurrentes (Swanson et al., 2010).

Tabla F1

Objetivos de recuperación iniciales

Servicio	Prioridad	RTO objetivo	RPO objetivo	Estrategia / validación
Portal de matrícula	Crítica	≤ 2 h	≤ 15 min	Protección DDoS externa, réplica/respaldos transaccionales consistentes, DNS alterno y prueba de transacción.
Sistema académico	Alta	≤ 4 h	≤ 1 h	Restauración de aplicación y BD en orden de dependencia; validar integridad con usuario funcional.
Sistema financiero	Alta	≤ 8 h	≤ 4 h	Copia cifrada y aislada; aprobación de Finanzas antes de reabrir procesamiento.
Correo institucional	Media-alta	≤ 8 h	≤ 4 h	Recuperación priorizada de identidad, DNS y mensajería; comunicación alternativa.
VMware/servicios base	Crítica	≤ 4 h	≤ 1 h de configuración	Copia independiente de configuraciones; acceso de emergencia probado; hipervisor limpio y monitoreado.
Respaldo central	Crítica	≤ 8 h	≤ 24 h de catálogo	Reconstrucción desde copia fuera de línea/inmutable; doble control de credenciales.

Secuencia de activación

1. Declarar incidente y responsable, preservar evidencia y determinar si hay compromiso activo.

2. Contener identidades/redes afectadas; no conectar copias protegidas al dominio sospechoso.

3. Confirmar punto de restauración limpio con integridad y escaneo; seleccionar orden portal, identidad/base de datos y dependencias.

4. Recuperar en entorno aislado, validar consistencia técnica y aceptación del dueño funcional.

5. Cambiar credenciales, reabrir tráfico gradualmente, monitorear y comunicar estado.

6. Documentar RTO/RPO real, pérdida, decisiones y tareas correctivas. Un ejercicio trimestral de mesa y una restauración técnica mensual comprobarán que el procedimiento, contactos, llaves y recursos siguen disponibles.

Anexo G. Declaración de uso de inteligencia artificial

Herramienta utilizada: GitHub Copilot (asistente de IA). Uso: apoyo para organizar la estructura del informe, redactar un borrador de análisis; cálculo manual de ventanas de caída; declaración explícita de supuestos; Profundo Analisis de cada tema y propuestas de comprensión del tema para la xorrecta toma de decisiones.